

EUNAVIA · SÄULE GESUNDHEIT (ARBEITSTITEL „VIVANOVA“)

Datenschutz-, Anonymitäts- & Cyber-Security-Strategie

Maximaler Datenschutz und nachweisbare Vertrauenswürdigkeit für die gesundheitssensiblen Apps — ohne Verlust an Funktion und Bedienbarkeit.

Fahrerwohl

KLAR (Alkohol)

Rauchfrei (Stop Smoking)

Lebensqualität (Quality of Life)

Eunavia (Dachmarke)

Erstellt am 14. Juni 2026 · Interne Strategiegrundlage

Quellen: Quellcode der Repositories, Konzept-PDFs der Projekte, Recherche zu TÜV-/DiGA-Zertifizierung.

Keine medizinische oder rechtsverbindliche Beratung — vor regulatorischen Schritten Fachjurist:in/DSB hinzuziehen.

Inhalt

1. Executive Summary — die Strategie in zehn Sätzen
2. Ausgangslage: Was die fünf Projekte heute tun (und wo das Risiko liegt)
3. Schutzbedarf & regulatorische Einordnung pro Projekt
4. Die acht Leitprinzipien
5. Kernkonzept I — Anonymität *und* Identifizierung: das Split-Identity-Modell
6. Kernkonzept II — „Ein Projekt, eine Festung“: Datenbank-Isolation gegen Breaches
7. Kernkonzept III — Verschlüsselung & Crypto-Shredding
8. Konkrete Datenbankstrukturen je Projekt
9. Die schnelle Notfall-/SOS-Funktion — Schutz *ohne* Funktionsverlust
10. Zertifizierung: das TÜV-Siegel (wie Lidl) und der DiGA-Pfad
11. Umsetzungs-Roadmap in fünf Phasen
12. Maßnahmen-Checkliste & offene Punkte
13. Glossar

1 · Executive Summary

Die Gesundheitsapps verarbeiten die schutzwürdigsten Daten, die es gibt (Sucht, mentale Gesundheit, Fahrtauglichkeit — **Art. 9 DSGVO**). Vertrauen ist hier nicht ein Feature, sondern *die* Geschäftsgrundlage. Diese Strategie macht Anonymität zum Standard, sperrt Daten projektweise gegeneinander ab und hält die App trotzdem schnell und einfach.

1 Local-First

Sensible Daten entstehen und bleiben primär auf dem Gerät (verschlüsselte On-Device-DB). Cloud nur als *optionaler*, Ende-zu-Ende-verschlüsselter Sync.

2 Anonym per Default

Kein Login, keine E-Mail, keine Klarnamen nötig. Identität (falls überhaupt) wird *getrennt* von den Gesundheitsdaten gespeichert (Split-Identity).

3 Eine Festung pro Projekt

Jedes Projekt bekommt eine **eigene** Datenbank, eigene Schlüssel, eigenes Hosting-Konto. Ein Breach kompromittiert nie alle Dienste auf einmal.

4 Pro-Nutzer-Verschlüsselung

Jeder Datensatz mit nutzereigenem Schlüssel (Envelope Encryption). Ein gestohlener Datenbank-Dump ist ohne die Schlüssel wertlos. Löschen = Schlüssel vernichten.

5 Notfall ohne Netz

Der SOS-/„Welle-reiten“-Knopf läuft komplett offline und ohne Account — Datenschutz bremsst die lebenswichtige Funktion nie aus.

6 Prüfbar durch TÜV

Zielsiegel „**TÜV geprüfte App**“ (TÜV Saarland — das Siegel von Lidl Plus), für die DiGA-Kandidaten zusätzlich **BSI TR-03161 + ISO 27001**.

Die zentrale Spannung — und ihre Auflösung. „Anonym“ und „die Leute müssen sich identifizieren“ widersprechen sich nur scheinbar. Die Lösung ist *Trennung*: Wer jemand ist (für Rezept-Einlösung, Behandler-Export, Geräte-Wiederherstellung) wird in einem separaten Identitäts-Tresor verwahrt, der **nie** erfährt, was die Person über ihre Gesundheit eingibt — und umgekehrt. Beide Hälften sind nur über ein pseudonymes Token verbunden, das allein nichts verrät.

2 · Ausgangslage — Stand heute

Befund aus dem Quellcode: **Alle fünf Apps speichern derzeit ausschließlich lokal** und haben kein Backend. Das ist datenschutzrechtlich ein guter Startpunkt (kein zentraler Datentopf, der lecken kann), aber es fehlen Verschlüsselung-at-rest auf dem Gerät, ein durchdachtes Identitäts-/Sync-Konzept und die Strukturen für die therapeutische Verlaufsbegleitung.

Projekt	Stack	Speicherung heute	Lücke
Fahrerwohl	Android nativ (Kotlin/Compose, Car App Library)	DataStore + SharedPreferences (Klartext-JSON), Singleton ShiftRepo	Unverschlüsselt on-device; Health-Connect-Anbindung offen
KLAR (Alkohol)	Pre-Code / Next.js-Gerüst begonnen	Konzept sieht verschlüsselte On-Device-DB + optionalen EU-Cloud-Sync vor	Noch kein Datenmodell, kein Auth, kein Sync gebaut
Rauchfrei	Next.js 16 statischer Export + Capacitor	localStorage (Key stop-smoking-support-state-v1)	Klartext im Browser-Storage; kein Backup/Gerätewechsel
Lebensqualität	Expo / React Native (iOS+Android+Web)	AsyncStorage / localStorage , ein zentraler Context-State	Modulübergreifendes Profil = höchste Korrelationsgefahr
Eunavia	Vite, statische Marketing-Site	Keine personenbezogenen Daten	Nur Geo-Cookie; unkritisch (kein Tracking ergänzen)

Wichtige Erkenntnis. Die Lebensqualitäts-Plattform ist das sensibelste Projekt: Ihr erklärter Wettbewerbsvorteil ist das *gemeinsame Profil über alle Domänen* (Sucht + Finanzen + Schlaf + Einsamkeit). Genau dieses Bündel ist auch das größte Datenschutzrisiko — ein einziger Datensatz zeichnet ein vollständiges Psychogramm. Hier ist die strikteste Trennung und Verschlüsselung Pflicht.

3 · Schutzbedarf & regulatorische Einordnung

Nicht jedes Projekt braucht denselben Aufwand. Die Apps teilen sich in zwei regulatorische Klassen — das bestimmt Zertifizierungspflichten und Kosten.

Projekt	Datenkategorie	Regulat. Klasse	Ziel-Compliance
Fahrerwohl	Gesundheitsförderung (Trinken, Bewegung, Stimmung, Standort)	WELLNESS	DSGVO + freiwilliges App-Siegel
KLAR (Alkohol)	Suchterkrankung, Craving, Medikation, Geo — Art. 9	DIGA-PFAD	DSGVO Art. 9 + BSI TR-03161 + ISO 27001
Rauchfrei	Tabakabhängigkeit, Trigger, Medikation — Art. 9	DIGA-PFAD	DSGVO Art. 9 + BSI TR-03161 + ISO 27001
Lebensqualität	Multi-Domänen-Psychogramm; einzelne Module Art. 9	WELLNESS → DIGA (Teilmodule)	DSGVO Art. 9; MDR-Abgrenzung; DiGA nur für Einzelmodule
Eunavia	Keine	—	DSGVO (Impressum, Cookie-Banner falls nötig)

Wellness (Fahrerwohl, QoL-Kern)

Präventiv/informativ, kein Diagnose-/Therapieanspruch. Es greift „nur“ die DSGVO. Freiwillige Siegel schaffen Vertrauen, sind aber nicht Pflicht.

DiGA-Kandidaten (KLAR, Rauchfrei)

Sobald therapeutischer Nutzen beansprucht und Erstattung angestrebt wird, gelten die harten BfArM-Anforderungen — verpflichtend, mit Zertifikatszwang.

MDR = EU-Medizinprodukteverordnung · DiGA = Digitale Gesundheitsanwendung („App auf Rezept“, BfArM) · Art. 9 DSGVO = besondere Kategorien personenbezogener Daten.

4 · Die acht Leitprinzipien

Diese Prinzipien sind in *jeder* Architektur- und Code-Entscheidung der Gesundheitsapps verbindlich (Art. 25 DSGVO — Datenschutz durch Technikgestaltung).

#	Prinzip	Konkrete Konsequenz im Code
1	Datensparsamkeit (Art. 5)	Nur erheben, was eine therapeutische Funktion zwingend braucht. Standort, Sensorik, Klarname: immer optional, defaultmäßig aus.
2	Anonym by Default	App funktioniert voll ohne Account. Zufalls-ID auf dem Gerät, keine PII-Pflicht.
3	Local-First	Rohdaten on-device verschlüsselt. Cloud ist Sync, nicht Quelle der Wahrheit.
4	Trennung Identität ↔ Gesundheit	Zwei Datenbanken, nur über pseudonymes Token verbunden (Split-Identity, §5).
5	Isolation pro Projekt	Getrennte DBs, Schlüssel, Konten. Keine projektübergreifende Nutzertabelle.
6	Verschlüsselung überall	At-rest, in-transit, Ende-zu-Ende beim Sync. Pro-Nutzer-Schlüssel.
7	Nutzerkontrolle (Art. 15–20)	Ein-Klick-Export (Behandler-Bericht) und Ein-Klick-Löschung (Crypto-Shredding).
8	Kein Datenhandel, keine Tracker	Null Werbe-SDKs, null Analytics-Drittanbieter. Erfolgsmetrik = Genesung, nicht Bildschirmzeit. Markenversprechen.

Harte Grenze. In keine der Gesundheitsapps kommen Werbe-/Tracking-SDKs (Facebook, Google Analytics, AppsFlyer o. Ä.). Sie würden Art.-9-Daten an Dritte übertragen und jede Zertifizierung sofort unmöglich machen. Telemetrie nur anonym, aggregiert, on-device-vorverarbeitet und opt-in.

5 · Kernkonzept I — Anonymität *und* Identifizierung

Die schwierigste Anforderung: Menschen sollen anonym bleiben, sich aber trotzdem identifizieren können (für Rezept-Einlösung, Behandler-Export, Wiederherstellung nach Geräteverlust) — und alles muss einfach bleiben. Lösung: das **Split-Identity-Modell**.

5.1 Die drei Identitätsstufen

Stufe	Wer das nutzt	Was gespeichert wird	Reibung
A — Anonym (Default)	Alle, sofort beim ersten Start	Nur eine lokal erzeugte Zufalls-ID (UUID) + Recovery-Schlüssel. Keine PII.	Null — kein Login-Screen
B — Pseudonym (opt-in)	Wer Cloud-Sync / Gerätewechsel / Buddy-System will	Passkey (gerätegebunden) <i>oder</i> Recovery-Code. Immer noch keine E-Mail nötig.	Sehr gering — ein Tap (Passkey/Face-ID)
C — Identifiziert (opt-in, nur bei Bedarf)	DiGA-Rezept einlösen, verifizierter Behandler-Export	Minimale Identitätsmerkmale — <i>im separaten Identitäts-Tresor</i> , nie neben den Gesundheitsdaten.	Nur einmalig, nur wenn der Nutzen es verlangt

5.2 Die physische Trennung — zwei Tresore, ein Token

Innerhalb *jedes* Projekts werden zwei strikt getrennte Datenspeicher betrieben:

Identitäts-Tresor (Identity Vault) Kennt — falls überhaupt — Passkey-Credential, Recovery-Hash, ggf. Rezept-/Verifizierungsmerkmale. Kennt keinerlei Gesundheitsdaten. Gibt nur ein pseudonymes <code>subject_token</code> aus.	Gesundheits-Tresor (Health Store) Speichert Assessments, Craving-Events, Verläufe — alle <i>ausschließlich</i> unter dem <code>subject_token</code> . Kennt keinen Namen, keine E-Mail, kein Gerät.
---	--

Die beiden Hälften verbindet allein das Token. Ein Angreifer, der den Gesundheits-Tresor erbeutet, hält pseudonyme Verläufe ohne Person; wer den Identitäts-Tresor erbeutet, hält Tokens ohne Gesundheitsinhalt. Erst die *Kombination beider plus der Schlüssel* ergäbe ein Re-Identifizierungsrisiko — und beide liegen getrennt, mit getrennten Zugängen.

```
# Datenfluss bei Stufe C (z. B. DiGA-Rezept einlösen)
Gerät —Passkey—> Identity Vault    (prüft Berechtigung, kennt 0 Gesundheitsdaten)
                        |
                        |— gibt aus: subject_token = "sjt_9f3c..." (pseudonym, rotierbar)
                        |
Gerät —subject_token—> Health Store    (liefert Verlauf, kennt 0 Identität)

# Re-Identifizierung nur durch berechtigte Stelle, nur mit beidseitigem Zugriff + Schlüssel
```

5.3 Wiederherstellung ohne E-Mail (das Proton-Prinzip)

Geräteverlust darf weder Datenverlust noch eine E-Mail-Pflicht bedeuten. Beim Anlegen erzeugt die App einen **Recovery-Schlüssel** (z. B. 12-Wort-Phrase oder Recovery-PDF wie beim Proton-Recovery-Kit).

Damit lässt sich der E2E-verschlüsselte Cloud-Sync auf einem neuen Gerät entschlüsseln — der Server sieht nie Klartext, kann den Schlüssel nicht wiederherstellen und nichts mitlesen.

Warum Passkeys statt Passwort/E-Mail. Passkeys (WebAuthn/FIDO2) sind gerätegebunden, phishing-resistent, brauchen keine E-Mail und keinen Klarnamen — perfekt für „identifizierbar, aber anonym“. Ein Tap mit Face-ID/Fingerabdruck genügt. Im Workspace bereits erprobt (Hanko-Passkeys bei [cyberschoolingparents](#)).

6 · Kernkonzept II — „Ein Projekt, eine Festung“

Vorgabe: jedes Projekt bekommt eine ganz eigene Datenbankstruktur, damit bei einem Breach nicht alle Daten auf einmal verloren gehen. Das ist gelebte Cyber-Security durch **Kompartimentierung** — und nebenbei ein Datenschutzgewinn, weil projektübergreifende Profilbildung technisch unmöglich wird.

6.1 Vier Isolations-Ebenen

Ebene	Maßnahme	Wirkung bei einem Breach
1 · Hosting	Eigenes Cloud-Projekt/-Konto pro App (eigener Neon-/Koyeb-Projekt, eigene Vercel-Org-Scopes), EU-Region	Kompromitierte Zugangsdaten eines Projekts öffnen kein anderes
2 · Datenbank	Eigene DB-Instanz pro App, eigene Credentials, eigene Netzwerk-/IP-Allowlist	Dump betrifft nur eine App; andere bleiben unberührt
3 · Schema	Pro App getrennte <i>Identity</i> - und <i>Health</i> -Datenbank (zwei DBs, nicht zwei Tabellen)	Selbst innerhalb einer App keine Re-Identifizierung aus einem Dump
4 · Schlüssel	Eigener KMS-/Master-Key pro App; pro Nutzer ein Datenschlüssel (Envelope Encryption)	DB-Dump ohne Schlüssel = unlesbar; ein Nutzerschlüssel ≠ alle

Bewusst KEINE gemeinsame Nutzertabelle über Projekte. Es wäre verlockend, einen zentralen „Eunavia-Account“ für alle Apps zu bauen. Für Gesundheitsdaten ist das Gift: Es schafft genau den einen Topf, dessen Leck alles offenlegt, und es verknüpft „raucht“ + „trinkt“ + „Fahrerberuf“ zu einem Profil. Stattdessen: Single-Sign-on optional und nur als *föderierte* Verknüpfung über pseudonyme Tokens, nie als geteilte Gesundheitsdatenbank.

6.2 Schichtung der Speicher pro App



Das Backend sieht beim E2E-Sync nur Chiffretext. Es ist ein „Zero-Knowledge“-Speicher: Es bewahrt Daten auf, kann sie aber nicht lesen.

7 · Kernkonzept III — Verschlüsselung & Crypto-Shredding

7.1 Drei Verschlüsselungs-Ebenen

Ebene	Technik	Schützt vor
In-Transit	TLS 1.3, Certificate Pinning in der App	Mitlesen im Netz, MITM
At-Rest (Gerät)	SQLCipher (AES-256), Schlüssel in Keystore/Secure Enclave	Verlorenes/gestohlenes Gerät, Geräte-Backup-Leak
At-Rest (Cloud)	Envelope Encryption: pro Nutzer ein Datenschlüssel (DEK), verschlüsselt mit projekteigenem Master-Key (KEK) im KMS	DB-Dump, Insider-Zugriff, Backup-Diebstahl
Ende-zu-Ende (Sync)	Client verschlüsselt vor Upload; Schlüssel aus Recovery-Phrase abgeleitet, nie am Server	Server-Kompromittierung, Zwangsherausgabe, neugieriger Betreiber

7.2 Löschen, das wirklich löscht — Crypto-Shredding

Art. 17 DSGVO (Recht auf Löschung) wird oft schlecht umgesetzt, weil Daten in Backups überleben. Lösung: Statt Datensätze zu suchen und zu löschen, wird **der nutzeigene Schlüssel vernichtet**. Sofort ist der gesamte Bestand dieser Person — auch in jedem Backup — kryptografisch unzugänglich, also de facto gelöscht. Ein Tap im Profil, sofort wirksam, nachweisbar.

Pseudonymisierung als Re-Identifizierungs-Bremse. Selbst für interne Auswertung/Forschung (etwa DiGA-Wirksamkeitsnachweis) werden Daten nur pseudonymisiert verarbeitet, mit getrennt verwahrtem Zuordnungsschlüssel und k-Anonymität bei Aggregaten (kein Wert, der weniger als *k* Personen betrifft, wird einzeln ausgewiesen).

8 · Konkrete Datenbankstrukturen je Projekt

Jedes Projekt erhält ein eigenes, auf seinen therapeutischen Ablauf zugeschnittenes Schema. Gemeinsam ist nur das *Muster* (Identity Vault getrennt vom Health Store, alles am `subject_token`), nicht die Tabellen. In der Cloud sind die Inhaltsspalten Ciphertext-Blobs; die Struktur unten zeigt die *logischen* Felder.

8.1 KLAR — Alkohol-Abstinenz DIGA-PFAD

Therapeutischer Kern aus dem Konzept: Eingangs-Assessment + Entzugsrisiko-Screening, Echtzeit-Hilfe im Verlangensmoment (JITAI „Notfall-Knopf“), stigmafreie Rückfallbegleitung (Lapse ≠ Relapse), Meilensteine, anonyme Peer-Begleitung, Behandler-Export.

IDENTITY VAULT (DB 1)	HEALTH STORE (DB 2 – alles je <code>subject_token</code>)
<code>passkey_credential</code>	<code>assessment</code> (severity, audit_score, withdrawal_risk, goal, p
<code>recovery_hash</code>	<code>ema_checkin</code> (ts, mood, craving_0_10, context) # EMA
<code>diga_redemption (opt.)</code>	<code>craving_event</code> (ts, trigger[], intensity, outcome)
↳ <code>subject_token</code>	<code>sos_session</code> (ts, type[urge_surf breath reappraisal], result)
	<code>lapse_event</code> (ts, trigger, reflection, plan_update) # kein
	<code>milestone</code> (kind, reached_at, reward)
	<code>medication</code> (drug[naltrexon acamprosat glp1], adherence)
	<code>program_progress</code> (module, lesson, status)
	<code>buddy_link</code> (peer_pseudonym) # anonym
	<code>export_share</code> (recipient_kind, scope, expires_at)

Geo-/Sensorik-Daten (Auslöser-Radar, Phase 2) bleiben **on-device** vorverarbeitet; nur abgeleitete Risiko-Flags (nicht Rohstandorte) wandern — wenn überhaupt — in den Sync.

8.2 Rauchfrei DIGA-PFAD

Kern: Fagerström-Abhängigkeit, Trigger-Tracking als „Herz der App“, Craving-SOS „Die Welle reiten“, Lapse-Recovery ohne Schuldbotschaft, KVT/ACT-Modulpfad.

IDENTITY VAULT (DB 1)	HEALTH STORE (DB 2)
<code>passkey / recovery</code>	<code>profile</code> (fagerstroem_score, quit_date, reasons[], why_ph
↳ <code>subject_token</code>	<code>craving_event</code> (ts, intensity_0_10, trigger[], mood, context, o
	<code>sos_session</code> (ts, steps_done[], result[managed smoked])
	<code>lapse_event</code> (ts, trigger, reflection) # Bilanz
	<code>program_step</code> (week, module, reflection)
	<code>milestone</code> (health_recovery_point, money_saved)
	<code>medication</code> (drug[vareniclin cytisin nrt], reminder)
	<code>export_report</code> (scope, created_at)

8.3 Lebensqualität — Multi-Modul WELLNESS → DIGA (Module)

Höchster Schutzbedarf wegen Domänen-Kopplung. Kern = ein Profil + Gewohnheits-Engine + täglicher Check-in; Module hängen sich ein.

IDENTITY VAULT (DB 1)

passkey / recovery
↳ subject_token

HEALTH STORE (DB 2)

profile	(goals[], life_context)	
daily_checkin	(ts, mood, sleep, energy)	
habit	(template, streak, schedule)	
habit_completion	(habit_id, ts)	
module_state	(module[sleep stress loneliness finance move par	
domain_metric	(module, scale, value, ts)	# je Dom
insight	(cross_domain_pattern, ts)	# NUR on
crisis_flag	(kind, escalation_ref)	

Sonderregel QoL. Die domänenübergreifenden „Insights“ (Finanzstress → Schlaf → Stimmung) sind der wertvollste, aber auch gefährlichste Datenpunkt. Sie werden **ausschließlich on-device** aus den Einzeldomänen berechnet und nie als fertiges Psychogramm in die Cloud gelegt. Jede Domäne bekommt einen *eigenen* Datenschlüssel, sodass ein Modul-Leak nicht alle Domänen offenlegt.

8.4 Fahrerwohl WELLNESS

Bewusst schlank: Schichtbegleitung, Trink-/Pausen-/Bewegungs-/Stimmungsverlauf. Konzept will Daten standardmäßig *auf dem Gerät* behalten.

ON-DEVICE ONLY (Default – kein Cloud-Zwang)

shift_state	(laufende Schicht, Pausen, Timer)	# heute: ShiftRepo → künftig SQLCipher
hydration_log	(ts, amount, target)	
pause_event	(ts, type[pause nap micro], duration)	
movement_log	(ts, steps, sit_minutes)	# via Health Connect, opt-in
mood_check	(ts, tension_before, tension_after)	
todo / checklist	(pre_trip, handover)	

OPTIONAL CLOUD (nur bei ausdrücklichem Wunsch)

→ Arbeitgeber-/Betriebsarzt-Export nur mit aktiver, widerrufbarer Einwilligung; Standort nur COARSE, nie über die Fahrt hinaus gespeichert.

Sofortmaßnahme Fahrerwohl: das heutige Klartext-DataStore-JSON auf eine verschlüsselte Room/SQLCipher-DB heben; Profil (Gewicht/Alter) aus SharedPreferences in **EncryptedSharedPreferences** .

9 · Die schnelle Notfall-/SOS-Funktion — Schutz ohne Funktionsverlust

Vorgabe: Datenschutz darf die Funktion nicht ausbremsen, und es braucht eine schnelle Notfallfunktion. Beides ist *kein* Widerspruch — im Gegenteil, ein lokaler Notfallpfad ist sowohl schneller *als auch* datensparsamer.

9.1 Designregeln für den SOS-Pfad

Regel	Begründung
Offline-first, null Netzabhängigkeit	Im Verlangens-/Krisenmoment darf nichts auf einen Server warten. Die „Welle-reiten“-/Atem-/Urge-Surfing-Sequenz liegt komplett lokal (ist in Rauchfrei bereits so gebaut: <code>CravingSupport</code> , <code>breathingPhases</code> lokal in <code>state.ts</code>).
Ohne Account erreichbar	SOS funktioniert in Stufe A (anonym). Kein Login-Gate vor lebenswichtiger Hilfe.
Krisenressourcen lokal gebündelt	Notrufnummern, Telefonseelsorge, Sucht-Hotlines fest in der App hinterlegt — kein Online-Lookup nötig. (KLAR: <code>CRISIS_RESOURCES</code> , <code>detectCrisis()</code> bereits angelegt.)
Vertrauensperson lokal	Optionaler SOS-Kontakt (Buddy) wird lokal gespeichert; Auslösen ruft direkt an/schreibt, ohne den Umweg über einen Server.
Event minimal & nachgelagert	Dass ein SOS stattfand, wird nur lokal und minimal protokolliert (für den eigenen Verlauf); ein etwaiger Sync passiert später, verschlüsselt, nie blockierend.

Kernaussage. Weil die wirksamsten Funktionen (SOS, Atem-Coach, Tracking) *ohnehin* on-device laufen, ist die datenschutzfreundliche Architektur zugleich die schnellste und robusteste. Der Nutzer-Vorteil und der Datenschutz zeigen in dieselbe Richtung.

9.2 Klinische Sicherheits-Eskalation

Bei erkannten Warnzeichen (Suizidalität, gefährlicher Alkoholzug — Krampf/Delir-Risiko) eskaliert die App **freundlich, aber konsequent** an menschliche/ärztliche Hilfe, statt selbst zu „therapieren“. Diese Eskalation ist Teil des Notfallpfads und ebenfalls netzunabhängig (lokale Notrufnummern). Diese Sicherheitsfunktion ist für den DiGA-Pfad zwingend.

10 · Zertifizierung — das TÜV-Siegel (wie Lidl) und der DiGA-Pfad

Recherche-Ergebnis: Die Lidl-Plus-App trägt das Siegel „TÜV geprüfte App“ des TÜV Saarland (TÜV TEKIT). Das ist ein herstellerunabhängiges App-Gütesiegel, das Nutzererfahrung, Rechtskonformität und Datensicherheit prüft. Es ist erreichbar — und der richtige erste Vertrauensanker für die Wellness-Apps.

10.1 Die passenden Siegel — gestaffelt nach Schutzbedarf

Siegel / Norm	Anbieter	Was es belegt	Für welches Projekt
TÜV geprüfte App	TÜV Saarland (TEKIT)	App-Gütesiegel: UX, Rechtskonformität, Datensicherheit (Lidl-Siegel)	Fahrerwohl, QoL (erster Vertrauensanker)
Trusted App	TÜViT (TÜV NORD) + mediaTest	Datenschutz + Datensicherheit + Schutzmechanismen, inkl. Quellcode-Analyse	Alle Apps, höherwertige Alternative
ePrivacyApp HS	ePrivacy GmbH	High-Security-Datenschutzsiegel speziell für sensible Apps (E-Health, Banking)	KLAR, Rauchfrei (sensibel)
BSI TR-03161	Akkred. Stelle (z. B. TÜViT, PwC)	Pflicht für DiGA seit 01/2025: Datensicherheit von App, Web & Backend (~385 Anforderungen)	KLAR, Rauchfrei (verpflichtend bei DiGA)
ISO/IEC 27001	Akkred. Zertifizierer	Informationssicherheits-Managementsystem (ISMS). Pflicht für DiGA seit 04/2022	Organisation (Voraussetzung für DiGA)
ISO/IEC 27701	Akkred. Zertifizierer	Datenschutz-Managementsystem (PIMS), baut auf ISO 27001 auf	Mittelfristig, Datenschutz-Reifegrad

10.2 Die zugrundeliegenden Prüf-Standards (auf die wir jetzt schon bauen)

- **OWASP MASVS / MSTG** — Mobile-App-Security-Standard; Grundlage jeder App-Penetrationstest-Prüfung (TÜViT, TÜV Süd). Bereits in der Entwicklung als Checkliste nutzen.
- **BSI TR-03161** — drei Teile (mobile App / Web / Backend), je separat zertifiziert. Wer die drei Festungsschichten (§6) sauber baut, erfüllt schon große Teile.
- **ISO 27001 / 27701** — organisatorisch (Richtlinien, Rollen, Incident-Response, Verschwiegenheitsverpflichtung). Auch als Ein-Personen-Unternehmen früh die Dokumentation anlegen.
- **DSGVO Art. 9 / DiGAV §4** — rechtlicher Kern; Datenschutz-Folgenabschätzung (DSFA) ist hier Pflicht.

10.3 Aufwand (grobe Orientierung)

Schritt	Dauer	Größenordnung Kosten
App-Penetrationstest (OWASP MASVS)	1–2 Wochen	ca. 4.000–8.000 € pro App
App-Gütesiegel (TÜV Saarland / Trusted App / ePrivacyApp)	mehrere Wochen	projektabhängig, individuell
ISO 27001 (ISMS aufbauen + Audit)	Monate	mittlerer 5-stelliger Bereich
BSI TR-03161 (DiGA, 3 Teile)	Monate, hoher Doku-Aufwand	hoch (Zertifikat verpflichtend)

Empfehlung zur Reihenfolge siehe §11. Festpreise veröffentlichen die TÜV-Stellen nicht — der Penetrationstest ist meist der größte Einzeiposten.

11 · Umsetzungs-Roadmap in fünf Phasen

Pragmatisch für ein kleines Team: erst die Grundlagen, die *jede* App braucht, dann Siegel dort, wo der Vertrauensgewinn am größten ist, zuletzt der teure DiGA-Pfad für die zwei klinischen Kandidaten.

Phase 0 — Fundament (sofort, kostenlos im Code)

- On-Device-Verschlüsselung in alle Apps: SQLCipher/EncryptedSharedPreferences (Fahrerwohl), WebCrypto-AES-GCM für localStorage (Rauchfrei, QoL).
- Werbe-/Analytics-SDKs ausschließen; Dependency-Audit. TLS 1.3 + Cert-Pinning vorbereiten.
- Anonym-by-Default umsetzen (Zufalls-ID, kein Login-Gate). Recovery-Schlüssel-Mechanik.
- OWASP-MASVS-Checkliste als Definition-of-Done in die Entwicklung aufnehmen.

Phase 1 — Split-Identity & Festungs-Backend (für Apps mit Sync)

- Pro Projekt zwei getrennte EU-DBs (Identity Vault + Health Store), eigene KMS-Keys, eigenes Hosting-Konto.
- Passkeys (Stufe B) + E2E-verschlüsselter, optionaler Cloud-Sync. Crypto-Shredding-Löschung.
- Envelope Encryption pro Nutzer; bei QoL zusätzlich Schlüssel pro Domäne.

Phase 2 — Recht & Dokumentation

- Datenschutz-Folgenabschätzung (DSFA) je Gesundheitsapp; Verzeichnis von Verarbeitungstätigkeiten; AV-Verträge mit EU-Hostern.
- Transparente Datenschutzerklärung + granulare Einwilligungs-Flows (v. a. Standort/Sensorik).
- ISMS-Grundlagen nach ISO 27001 anlegen (Richtlinien, Incident-Response, Verschwiegenheit).

Phase 3 — Erstes TÜV-Siegel (Vertrauensanker)

- Penetrationstest + „TÜV geprüfte App“ (oder Trusted App) zuerst für **Fahrerwohl** und die **Lebensqualitäts-Plattform** (sichtbarster Marketing-Effekt, geringere Hürde).
- Für KLAR/Rauchfrei das sensible **ePrivacyApp HS** anstreben.

Phase 4 — DiGA-Pfad (nur KLAR & Rauchfrei)

- ISO 27001 zertifizieren, BSI TR-03161 (3 Teile) zertifizieren, BfArM-Datenschutzkriterien erfüllen.
- Wirksamkeitsstudie für den „positiven Versorgungseffekt“; DiGA-Antrag beim BfArM.

12 · Maßnahmen-Checkliste & offene Punkte

Sofort umsetzbar (Code)

- ☐ Fahrerwohl: DataStore-Klartext → Room + SQLCipher; Profil → EncryptedSharedPreferences.
- ☐ Rauchfrei & QoL: localStorage/AsyncStorage-Inhalt clientseitig (AES-GCM) verschlüsseln.
- ☐ Alle Gesundheitsapps: Dependency-Audit, jegliche Werbe-/Analytics-SDKs entfernen/ausschließen.
- ☐ Anonyme Zufalls-ID + Recovery-Schlüssel statt Pflicht-Login einführen.
- ☐ SOS-/Krisenpfad als offline-, account-freie Funktion verifizieren (Krisennummern lokal).
- ☐ OWASP-MASVS-Checkliste in die Definition-of-Done aufnehmen.

Architektur (Backend, sobald Sync gebaut wird)

- ☐ Pro Projekt eigenes EU-Hosting-Konto, eigene DB-Instanz, eigene Credentials.
- ☐ Identity Vault und Health Store als zwei getrennte Datenbanken; nur `subject_token` verbindet.
- ☐ Eigener KMS-Master-Key pro Projekt; Envelope Encryption pro Nutzer (QoL: pro Domäne).
- ☐ Passkeys (WebAuthn) für Stufe B; E2E-Sync mit aus Recovery-Phrase abgeleitetem Schlüssel.
- ☐ Crypto-Shredding-Löschpfad (Art. 17) inkl. Backups.
- ☐ Keine projektübergreifende gemeinsame Nutzer-/Gesundheitstabelle.

Organisation & Recht

- ☐ DSFA pro Gesundheitsapp; Verarbeitungsverzeichnis; AV-Verträge (EU-Hoster).
- ☐ Datenschutzerklärung + granulare, widerrufbare Einwilligungen.
- ☐ ISMS-Doku (ISO 27001) früh beginnen; Incident-Response-Plan; Verschwiegenheitsverpflichtungen.
- ☐ Fach-/Rechtsberatung (DSB, Medizinrecht) vor DiGA-/MDR-Schritten einholen.

Offene Entscheidungen für Dich

- **Hoster:** EU-Region festlegen (Neon EU / Koyeb / Hetzner). Kein US-Cloud für Art.-9-Daten ohne zusätzliche Garantien.
- **Reihenfolge der Siegel:** Empfehlung — Fahrerwohl + QoL zuerst „TÜV geprüfte App“, KLAR/Rauchfrei direkt auf den sensiblen DiGA/ePrivacy-Pfad. Bestätigen?
- **DiGA-Ambition:** Soll wirklich Erstattung angestrebt werden (großer Aufwand, große Reichweite) — oder bleiben KLAR/Rauchfrei zunächst Wellness?
- **Buddy-/Community-Feature:** erhöht den Schutzbedarf deutlich (Daten verlassen das eigene Gerät). Früh oder später?

13 · Glossar

Begriff	Bedeutung
Art. 9 DSGVO	Besondere Kategorien personenbezogener Daten (u. a. Gesundheit) — verschärfter Schutz, Verarbeitung nur mit ausdrücklicher Einwilligung.
DiGA / BfArM	Digitale Gesundheitsanwendung („App auf Rezept“); das Bundesinstitut für Arzneimittel und Medizinprodukte führt das Verzeichnis und prüft.
BSI TR-03161	Technische Richtlinie des BSI zur Datensicherheit von Gesundheits-Apps; seit 01/2025 für DiGA zertifizierungspflichtig.
Envelope Encryption	Pro Nutzer/Datensatz ein eigener Datenschlüssel (DEK), der mit einem übergeordneten Master-Key (KEK) verschlüsselt wird.
Crypto-Shredding	Löschen durch Vernichten des Schlüssels — Daten werden kryptografisch unzugänglich, auch in Backups.
E2E / Zero-Knowledge	Ende-zu-Ende-Verschlüsselung; der Server speichert nur Chiffretext und kann die Inhalte nicht lesen.
Passkey (WebAuthn/FIDO2)	Gerätegebundene, phishing-resistente Anmeldung ohne Passwort und ohne E-Mail.
JITAI / EMA	Just-in-Time Adaptive Intervention / Ecological Momentary Assessment — Echtzeithilfe und Mikro-Check-ins im Moment.
OWASP MASVS	Mobile Application Security Verification Standard — Prüfmaßstab für App-Sicherheit.
k-Anonymität	Aggregat-Schutz: ein Wert wird nur ausgewiesen, wenn er mindestens k Personen betrifft (keine Einzel-Re-Identifizierung).